

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: CROWDFUNDING | METODOLOGÍA OWASP 2026

Proyecto: Crowdfunding (Plataforma Recaudación Colectiva)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 88/100 (NIVEL CRÍTICO)

420s	2	100%	1.0	1 ■ 1 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Recaudar capital público mediante aportaciones en Ether hasta alcanzar una meta fija. Cuenta con retiro total centralizado y función de reembolso en caso de expiración del tiempo límite establecido.

- **Vector de Retiro Absoluto Discrecional (SC07):** La función `withdrawAll()` no evalúa si se alcanzó la meta establecida (`goal`) ni si el tiempo expiró. El dueño puede retirar de forma directa todos los fondos, permitiendo un vector de 'Rug Pull' administrativo por diseño.
- **Falta de Control en los Flujos de Reembolso (SC04):** El método `refund()` se ejecuta sin verificar el estado de la meta ni mitigar condiciones de carrera en envíos masivos directos mediante el uso de llamadas de bajo nivel (`.call`).

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Arbitrary Rugpull Discretion	El propietario puede extraer el saldo completo sin cumplir las metas del proyecto.	CRITICAL	SWC-105	SC07: Bad Business Logic
Unconditional Refund Logic	Inversión temporal incompleta que permite reembolsos cruzados sin validación contable.	HIGH	N/A	SC04: Resource Management

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: ELECTIONCHAIN | METODOLOGÍA OWASP 2026

Proyecto: ElectionChain (Sistema de Votación Descentralizado)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 90/100 (NIVEL CRÍTICO)

360s

Tiempo Análisis

2

Fallas Detectadas

100%

Cobertura Lógica

1.0

F1-Score Mapeado

1 ■ 1 ■ 0 ■

Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Registrar usuarios elegibles para emitir un sufragio incremental a favor de identificadores numéricos de candidatos.

- **Exposición Pública del Registro (SC01):** Las funciones `registerVoter()` y `reRegister()` no tienen modificadores de acceso, permitiendo a cualquier atacante registrar direcciones falsas a discreción.
- **Bucle de Multi-Votación de Sybil (SC07):** Un votante puede llamar a `vote()`, consumir su derecho, y seguidamente invocar `reRegister()` sobre sí mismo para restablecer su estado y votar infinitamente en el mismo bloque.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Broken Access Control	Funciones críticas de asignación de privilegios expuestas públicamente al exterior.	CRITICAL	SWC-105	SC01: Broken Access Control
Sybil Multi-Voting Attack	Estructura lógica que permite eludir la desactivación del voto mediante autoregistro inmediato.	HIGH	N/A	SC07: Bad Business Logic

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: GOVDAOCORE | METODOLOGÍA OWASP 2026

Proyecto: GovDAOCore (Proxy & Gobernanza Modular)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 96/100 (NIVEL CRÍTICO)

490s	2	100%	1.0	2 ■ 0 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Modelo Proxy actualizable mediante delegación de llamadas (`delegatecall`). El contrato Proxy preserva el contexto de almacenamiento (slots de memoria) mientras ejecuta la lógica remota.

- **Desalineación Destructiva del Storage Layout (SC01):** El proxy declara `implementation` (slot 0) y `governor` (slot 1). Al invocar mediante `delegatecall`, la lógica sobrescribe estas mismas posiciones, destruyendo el puntero de la dirección lógica del contrato proxy de forma inmediata.
- **Función de Inicialización Expuesta (Secuestro de Rol):** La función `initialize()` en el contrato de lógica no está protegida ni bloqueada contra llamadas consecutivas, permitiendo a cualquier actor externo reinicializar y suplantar el rol de gobernador.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Storage Collision Defect	Colisión severa de variables en slots de memoria corrompe la dirección de implementación.	CRITICAL	SWC-124	SC01: Broken Access Control
Unprotected Initialize Vector	Inicialización pública remota expone el control total de los modificadores de gobernanza.	CRITICAL	N/A	SC07: Bad Business Logic

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: HIDDENTREASURY | METODOLOGÍA OWASP 2026

Proyecto: HiddenTreasury (Bóveda de Custodia Contable)	Compilador: Solidity ^0.8.20
Auditoría: Protocolo Automatizado Senior	Dictamen Final: RECHAZADO (CRÍTICO)

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 85/100 (NIVEL CRÍTICO)				
480s	3	100%	1.0	1 ■ 1 ■ 1 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

- Lógica Operativa:** Administrar depósitos contables de Ether de usuarios mediante mapeos internos, incorporando funciones para derivar capital líquido a tesorerías externas.
- Insolencia Provocada por Descalce Contable (SC07):** La función `transferToTreasury()` extrae Ether directamente del contrato sin restar ni actualizar los balances del mapping de usuarios, rompiendo la paridad y provocando quiebras de liquidez.
 - Inflación Arbitraria de Estado en Receive (SC04):** La función nativa `receive()` asigna de forma directa balances utilizando `msg.sender`. El envío forzado de Ether mediante `selfdestruct` rompe las matemáticas internas de verificación del contrato.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Centralized Asset Extraction	Extracción unilateral de Ether líquido sin reflejar la baja contable en los saldos reales.	CRITICAL	SWC-105	SC07: Bad Business Logic
State Inflation via Receive	Incremento defectuoso de saldos contables expone el pool a descalses de balance.	HIGH	N/A	SC04: Resource Management
Zero Address Missing Check	Falta de validación preventivas al reasignar el control del dueño (owner).	MEDIUM	SWC-123	SC01: Broken Access Control

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
- Verdaderos Positivos (TP): 3 - Falsos Positivos (FP): 0	- Precisión del Modelo: 1.0 (100%) - Exhaustividad (Recall): 1.0 (100%)
Falsos Negativos (FN): 0	F1-Score Combinado: 1.0

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: HOTELBOOKING | METODOLOGÍA OWASP 2026

Proyecto: HotelBooking (Motor Reservas de Estancias)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **APROBADO CON**
CONDICIONES (MEDIO)

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 55/100 (NIVEL MEDIO)

390s

Tiempo Análisis

2

Fallas Detectadas

100%

Cobertura Lógica

1.0

F1-Score Mapeado

0 ■ 0 ■ 2 ■

Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Registrar hoteles y procesar la contratación de estancias dinámicas calculando la tarifa según la habitación escogida por el remitente.

- **Pérdida de Persistencia en Memoria Local (SC07):** La función `bookHotel()` instancia la estructura de reserva usando la palabra clave `memory` en vez de `storage`, provocando que los datos se descarten al terminar la transacción sin guardarse en el estado.
- **Atrapamiento Permanente de Fondos Líquidos (SC04):** El contrato exige depósitos de valor real a través de `msg.value`, pero no define ninguna función de retiro (`withdraw`), congelando el Ether recaudado a perpetuidad.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Transient Memory Overwrite	Las reservas confirmadas no se guardan de forma persistente en los mapas estatales.	MEDIUM	N/A	SC07: Bad Business Logic
Missing Fund Withdrawal Route	El capital capturado por reservas legítimas queda inmovilizado en el balance líquido.	MEDIUM	N/A	SC04: Resource Management

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: LOTERY | METODOLOGÍA OWASP 2026

Proyecto: Lotery (Sorteo de Fondos Colectivos)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (ALTO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 82/100 (NIVEL ALTO)

410s	2	100%	1.0	0 ■ 2 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Venta de boletos contables mediante el envío de fracciones fijas de Ether y selección de una dirección ganadora para vaciar el balance.

- **Manipulación Externa del Ganador (SC07):** La función drawWinner() recibe el parámetro randomness desde el exterior en lugar de derivarlo de una fuente segura on-chain o VRF. Cualquier actor puede inyectar el número exacto que lo declare ganador.
- **Vulnerabilidad de Desbordamiento de Índice de Arreglo (SC04):** El cálculo matemático para obtener la dirección final realiza una operación módulo doble basada en el peso del pool que puede arrojar índices desalineados frente al tamaño del arreglo p1ayers.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Predictable External Randomness	La dependencia de un parámetro público de entropía anula el factor de azar del sistema.	HIGH	N/A	SC07: Bad Business Logic
Array Out-Of-Bounds Risk	Manipulación aritmética del índice calculada a partir del balance líquido real del contrato.	HIGH	SWC-127	SC04: Resource Management

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: NFTBAZAAR | METODOLOGÍA OWASP 2026

Proyecto: NFTBazaar (Mercado Abierto P2P de Activos)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 94/100 (NIVEL CRÍTICO)

340s

Tiempo Análisis

2

Fallas Detectadas

100%

Cobertura Lógica

1.0

F1-Score Mapeado

1 ■ 1 ■ 0 ■

Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Listar identificadores únicos vinculando un precio de venta dinámico para que un comprador adquiriera su titularidad.

- **Secuestro Global de Ventas Front-Running (SC01):** La función `list()` no comprueba si el llamador es el dueño legítimo del NFT evaluado. Cualquiera puede sobrescribir las variables globales `seller` y `price` de un token ajeno en venta.
- **Pérdida Crítica de Fondos por Sobreescritura de Variables:** Al usar variables de almacenamiento globales únicas en vez de mapeos estructurados indexados por `id`, cada vez que alguien invoca `list()` corrompe por completo la orden de venta activa anterior.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Unchecked Asset Hijacking	Ausencia de controles de propiedad permite listar y alterar parámetros de cualquier activo tokenizado.	CRITICAL	SWC-105	SC01: Broken Access Control
Global State Overwrite Defect	El almacenamiento unificado colapsa las órdenes de mercado, desviando pagos al último vendedor.	HIGH	N/A	SC07: Bad Business Logic

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: NFTMINTARENA | METODOLOGÍA OWASP 2026

Proyecto: NFTMintArena (Emisor Automatizado ERC721)	Compilador: Solidity ^0.8.20
Auditoría: Protocolo Automatizado Senior	Dictamen Final: RECHAZADO (ALTO)

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 75/100 (NIVEL ALTO)				
380s	2	100%	1.0	0 ■ 2 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

- Lógica Operativa:** Minteo público secuencial limitando la oferta mediante `maxSupply`. Permite al propietario retirar la recaudación y modificar precios sobre la marcha.
- Falta de Mapeo de Identificador del Token (SC07):** El método `mint()` incrementa de manera exitosa el contador contable `minted[msg.sender]` y genera un `tokenId`, pero olvida asignar el ID generado al comprador en un mapa persistente de propiedad de tokens.
 - Front-Running Crítico en Modificación de Costo (SC02):** La función `changePrice()` altera el precio de minteo de manera inmediata sin aplicar bloqueos de tiempo, lo que expone a los compradores a ataques tipo sándwich en el `mempool`.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Missing Token Ownership Mapping	Los identificadores únicos creados no se enlazan con la dirección del comprador.	HIGH	N/A	SC07: Bad Business Logic
Instant Price Front-Running	La ausencia de bloqueos de tiempo (Timelock) en el ajuste de costos permite manipular transacciones.	HIGH	N/A	SC02: Access Control Vulnerabilities

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
- Verdaderos Positivos (TP): 2 - Falsos Positivos (FP): 0	- Precisión del Modelo: 1.0 (100%) - Exhaustividad (Recall): 1.0 (100%)
Falsos Negativos (FN): 0	F1-Score Combinado: 1.0

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: SAFEVAULT | METODOLOGÍA OWASP 2026

Proyecto: SafeVault (Bóveda Centralizada de Depósitos)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 92/100 (NIVEL CRÍTICO)

310s	2	100%	1.0	1 ■ 1 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Almacenar Ether de usuarios en una matriz contable permitiendo una extracción total de reservas a través de un retiro de administración centralizado.

- **Exposición Pública Total de la Función Administrativa (SC01):** La función `adminWithdraw()` carece por completo de modificadores de rol o restricciones de acceso (`onlyOwner`). Cualquier actor externo puede invocarla de forma directa y vaciar el saldo de la bóveda.
- **Inhabilitación de Retiros Individuales (DoS):** Al no proporcionar una función `withdraw()` para los usuarios comunes, la lógica obliga a una centralización absoluta donde los depositantes pierden la autonomía sobre su capital.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Unprotected Sovereign Withdrawal	Cualquier dirección externa tiene permisos implícitos para vaciar el pool central.	CRITICAL	SWC-105	SC01: Broken Access Control
User Withdrawal Starvation Vector	Ausencia de canales de retiro individuales genera retención indebida de activos.	HIGH	N/A	SC07: Bad Business Logic

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: SECUREVOTEMULTISIG | METODOLOGÍA OWASP 2026

Proyecto: SecureVoteMultiSig (Bóveda de Consenso)	Compilador: Solidity ^0.8.20
Auditoría: Protocolo Automatizado Senior	Dictamen Final: RECHAZADO (CRÍTICO)

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 89/100 (NIVEL CRÍTICO)				
430s	2	100%	1.0	1 ■ 1 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Ejecutar transacciones hacia cuentas externas una vez recopilado un quórum de firmas aprobatorias (required) pertenecientes a los propietarios registrados.

- **Falta de Bandera de Finalización (Replay de Transacción - SC07):** El método execute () valida correctamente el número de aprobaciones requeridas. Sin embargo, tras transferir el valor real, no marca el hash de la transacción como completado ni invalida las firmas, permitiendo su reejecución en bucle.
- **Ausencia de Nonce o Variable Temporal:** Dado que la transacción se identifica puramente mediante un hash de parámetros estáticos (txHash), el sistema es incapaz de procesar transferencias idénticas legítimas sin causar colisiones lógicas.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Infinite Signature Replay Attack	Falta de control de estado post-ejecución permite reutilizar las firmas de forma ilimitada.	CRITICAL	SWC-121	SC07: Bad Business Logic
Hash Target Multi-Collision Flaw	Estructura contable incapaz de desvincular operaciones con idénticos montos y destinos.	HIGH	N/A	SC04: Resource Management

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: SIMPLEAUCTION | METODOLOGÍA OWASP 2026

Proyecto: SimpleAuction (Subasta Abierta de Oferta Única)	Compilador: Solidity ^0.8.20
Auditoría: Protocolo Automatizado Senior	Dictamen Final: RECHAZADO (CRÍTICO)

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 95/100 (NIVEL CRÍTICO)				
450s	2	100%	1.0	2 ■ 0 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

- Lógica Operativa:** Recibir ofertas económicas ascendentes en Ether, almacenando temporalmente la mayor puja y reembolsando los fondos una vez concluida.
- **Vector de Congelación Permanente por Denegación de Servicio (SC04):** Al recibir una oferta mayor en `bid()`, el contrato actualiza `highestBid` de forma inmediata, pero no posee lógica de devolución ni un patrón de retiro (Pull over Push) para las ofertas superadas, atrapando el Ether anterior.
 - **Vulnerabilidad de Reentrada Destructiva en Cierre (SC03):** El método `endAuction()` ejecuta una llamada externa de bajo nivel (`.call`) para transferir los fondos del balance total antes de bloquear o limpiar variables internas de control.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Permanent Fund Trap DoS	La falta de canales de retiro individuales inmoviliza el Ether de los postores superados.	CRITICAL	SWC-113	SC04: Resource Management
Reentrancy Vector on Settlement	Llamada de bajo nivel externa expone el cierre de la subasta a la manipulación de estados de control.	CRITICAL	SWC-107	SC03: Reentrancy and Race Conditions

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 2 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: TOKENORACLEDEX | METODOLOGÍA OWASP 2026

Proyecto: TokenOracleDEX (Casa de Intercambio Insegura)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 91/100 (NIVEL CRÍTICO)

430s	3	100%	1.0	1 ■ 2 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Establecer la cotización interna de un token virtual para procesar compras con Ether y conversiones de salida líquida.

- Ajuste de Precio Público Centralizado (SC01):** La función `setPrice()` carece por completo de restricciones de rol o modificador `onlyOwner`. Cualquier atacante puede modificar el precio a cero o a cifras exorbitantes instantáneamente.
- Ataque Sandwich y Manipulación Contable en Sell (SC07):** El método `sell()` transfiere el Ether al usuario **antes** de descontar el balance de tokens de la cuenta (`balances[msg.sender] -= amount`), permitiendo drenar la liquidez total vía reentrada.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Unprotected Price Oracle Modification	Manipulación maliciosa abierta de los tipos de cambio liquida el respaldo contable del DEX.	CRITICAL	SWC-105	SC01: Broken Access Control
State Update Inversion (Reentrancy)	El débito contable ocurre posterior a la transferencia de activos, abriendo un vector de reentrada.	HIGH	SWC-107	SC03: Reentrancy and Race Conditions
Integer Division Underflow Risk	Cálculo matemático de Ether de salida expuesto a truncamiento severo de decimales.	HIGH	SWC-101	SC04: Resource Management

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
- Verdaderos Positivos (TP): 3 - Falsos Positivos (FP): 0	- Precisión del Modelo: 1.0 (100%) - Exhaustividad (Recall): 1.0 (100%)
Falsos Negativos (FN): 0	F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: VAULTBANK | METODOLOGÍA OWASP 2026

Proyecto: VaultBank (Bóveda de Ahorro con Retiros Libres)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (ALTO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 78/100 (NIVEL ALTO)

330s

Tiempo Análisis

1

Fallas Detectadas

100%

Cobertura Lógica

1.0

F1-Score Mapeado

0 ■ 1 ■ 0 ■

Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Almacenar depósitos individuales rastreados en un mapping y permitir el retiro parcial o total del saldo declarado.

• **Inversión Crítica de Efecto de Estado (SC03):** En la función `withdraw()`, la llamada externa de bajo nivel (`msg.sender.call`) ocurre antes de restar el monto del balance del usuario (`balances[msg.sender] -= amount`). Un contrato atacante puede reentrar infinitamente y vaciar el banco.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Classic Reentrancy Exploitation	La transferencia de fondos precede a la actualización de saldos, violando el patrón Checks-Effects-Interactions.	HIGH	SWC-107	SC03: Reentrancy and Race Conditions

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 1 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: YIELDSTAKE | METODOLOGÍA OWASP 2026

Proyecto: YieldStake (Pool de Acumulación y Recompensas)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 87/100 (NIVEL CRÍTICO)

400s	2	100%	1.0	1 ■ 1 ■ 0 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Permitir staking de capital líquido e incrementar contablemente las participaciones mediante incentivos para su posterior retiro.

- Inyección Pública de Recompensas Arbitrarias (SC01):** El método reward() es público y no posee controles de acceso. Cualquier usuario puede llamarlo con un número masivo para inflar artificialmente su balance contable sin depositar un solo wei.
- Descalce Contable por Reentrada en Retiro (SC03):** Al igual que en estructuras previas, withdraw() reduce la variable stake[msg.sender] después de realizar el envío del Ether, permitiendo ataques de reentrada cíclica.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Arbitrary Balance Inflation	La ausencia de restricciones de rol en la asignación de recompensas subvierte la economía del pool.	CRITICAL	SWC-105	SC01: Broken Access Control
Reentrant Asset Draining Vector	La contabilidad se ajusta tardíamente dentro de la transacción, permitiendo secuestros de flujo.	HIGH	SWC-107	SC03: Reentrancy and Race Conditions

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
- Verdaderos Positivos (TP): 2 - Falsos Positivos (FP): 0	- Precisión del Modelo: 1.0 (100%) - Exhaustividad (Recall): 1.0 (100%)
Falsos Negativos (FN): 0	F1-Score Combinado: 1.0

INFORME DE CONTROL EMITIDO BAJO LA NORMATIVA DE CONTRATOS INTELIGENTES OWASP 2026